Bài 1: BẢO MẬT THÔNG TIN VÀ DỮ LIỆU CÁ NHÂN

Giảng viên: Trường ĐH Thủ đô Hà Nội

Nội dung chính

- Khái niệm về An toàn thông tin (ATTT).
- Các mối đe dọa phổ biến.
- Bảo vệ dữ liệu cá nhân.
- Các biện pháp bảo mật thực hành.
- Quy định pháp luật và đạo đức.

Tại sao cần bảo mật thông tin?

Bối cảnh: Sự bùng nổ của chuyển đổi số và dữ liệu lớn.

Hậu quả khi mất an toàn:

- Mất tiền, tài sản.
- Lộ thông tin riêng tư.
- Mất danh tiếng.
- Vi phạm pháp luật.

> *"Bạn đã từng bị mất tài khoản mạng xã hội hay nhận tin nhắn lừa đảo chưa?"*

Khái niệm về ATTT - Mô hình CIA

Tính bảo mật (Confidentiality)

Ngăn chặn truy cập trái phép. Đảm bảo chỉ những người được ủy quyền mới có thể xem dữ liệu.

Tính toàn vẹn (Integrity)

Ngăn chặn sửa đổi dữ liệu trái phép. Đảm bảo dữ liệu chính xác và đáng tin cậy.

Tính sẵn sàng (Availability)

Dữ liệu luôn có sẵn khi cần. Hệ thống hoạt động liên tục phục vụ người dùng.

Các mối đe dọa
Phần mềm độc hại (Malware).

Định nghĩa: Phần mềm độc hại (Malware).

Các loại chính:

- **Virus:** Lây lan khi đính kèm vào tệp tin.
- **Worm (Sâu):** Tự động nhân bản qua mạng.
- **Trojan:** Giả dạng phần mềm hợp pháp để đánh cắp thông tin.

Các mối đe dọa - Ransomware & Spyware

Ransomware

Mã hóa dữ liệu để tống tiền.

(Vấn đề thời sự nóng hổi hiện nay)

Spyware (Phần mềm gián điệp)

Theo dõi thao tác bàn phím (Keylogger) để lấy mật khẩu và thông tin cá nhân.

Các mối đe dọa (Social Engineering)

Khái niệm: Tấn công vào tâm lý con người.

Phishing (Lừa đảo):

Giả danh ngân hàng, cơ quan nhà nước qua Email/SMS để yêu cầu cung cấp mã OTP, mật khẩu.

> ***Dấu hiệu nhận biết:*** *Link lạ, yêu cầu khẩn cấp, sai lỗi chính tả.*

Preparing the ground for the attack:

- Identifying the victim(s).
- Gathering background information.
- Selecting attack method(s).

suspicion:

lware.

natural end.

Deceiving the vi

- Engaging the ta
- Spinning a story
- Taking control o

Obtaining the information over a period of time:

- Expanding foothold.
- Executing the attack.
- Disrupting business or/and siphoning data.

Dữ liệu cá nhân là gì?

Dữ liệu cá nhân cơ bản

- Họ tên
- Ngày sinh
- Địa chỉ
- Số điện thoại

Dữ liệu cá nhân nhạy cảm

- Tình trạng sức khỏe
- Quan điểm chính trị
- Dữ liệu sinh trắc học
- Tài khoản ngân hàng

Quyền và Trách nhiệm về dữ liệu cá nhân

Khung pháp lý

Nghị định 13/2023/NĐ-CP

Quyền của chủ thể dữ liệu:

- Quyền được biết
- Quyền đồng ý
- Quyền xóa dữ liệu

Trách nhiệm sinh viên

Phải có trách nhiệm khi thu thập hoặc xử lý dữ liệu của người khác.

"Tôn trọng quyền riêng tư của người khác cũng là bảo vệ chính mình."

Biện pháp bảo vệ - Quản lý mật khẩu

Thế nào là mật khẩu mạnh?

- > 12 ký tự.
- Bao gồm chữ hoa, chữ thường, số, ký tự đặc biệt.

Quy tắc vàng:

Không dùng thông tin cá nhân (ngày sinh, tên) làm mật khẩu.

> ***Công cụ:*** *Sử dụng phần mềm quản lý mật khẩu (Password Manager) như LastPass, 1Password, Bitwarden.*

Biện pháp bảo vệ - Xác thực đa yếu tố

Nguyên tắc: Có mật khẩu là chưa đủ.

Cái bạn biết

Mật khẩu (Password), PIN.

Cái bạn có

OTP qua điện thoại, Token, Ứng dụng Authenticator.

Cái bạn là

Sinh trắc học: Vân tay, FaceID.

Biện pháp bảo vệ - Tường lửa & Diệt Virus

- **Firewall (Tường lửa):**
  Rào chắn giám sát luồng dữ liệu vào/ra máy tính, ngăn chặn truy cập lạ.
- **Antivirus:**
  Phát hiện và tiêu diệt phần mềm độc hại. Cần cập nhật mẫu virus mới thường xuyên.
- **Cập nhật phần mềm (Update):**
  Vá các lỗ hổng bảo mật của hệ điều hành và ứng dụng.

Biện pháp bảo vệ - Sao lưu dữ liệu (Backup)

Nguyên tắc 3-2-1

3

Bản sao

Luôn giữ ít nhất 3 bản sao dữ liệu quan trọng của bạn.

2

Loại phương tiện

Lưu trữ trên 2 loại thiết bị khác nhau (Ví dụ: Ổ cứng máy tính & Cloud).

1

Bản lưu trữ Offline

Giữ 1 bản sao ngoại tuyến (ổ cứng rời không cắm thường xuyên) để đề phòng Ransomware.

An toàn khi sử dụng Internet

Wi-Fi công cộng

Hạn chế đăng nhập ngân hàng, mua sắm trực tuyến khi dùng mạng miễn phí.

Giao thức HTTPS

Luôn kiểm tra biểu tượng ổ khóa trên thanh địa chỉ trình duyệt.

Quyền riêng tư MXH

Thiết lập ai có thể thấy thông tin, bài viết và ảnh của bạn.

Tổng kết & Thảo luận

"An toàn thông tin là trách nhiệm của mỗi cá nhân."

Bài tập nhỏ:

Hãy bật xác thực 2 lớp (2FA) cho tài khoản Email sinh viên ngay tại lớp.